DATABASES
for Hackers

A Ronin 48 Stand-Up Talk

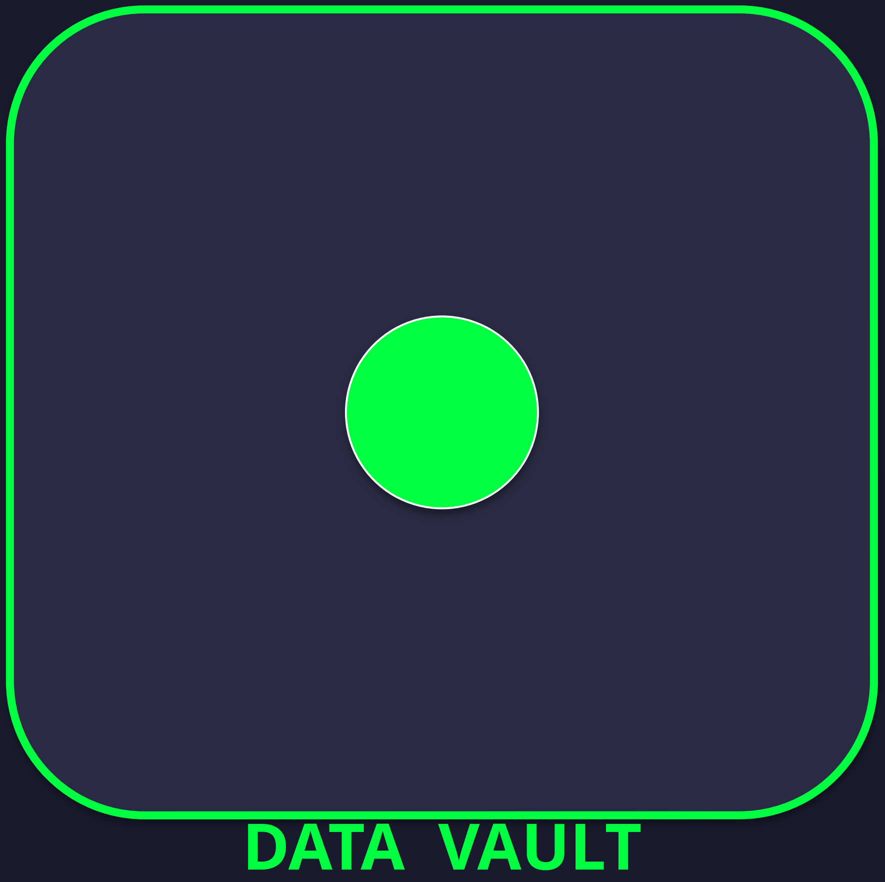
45 minutes • No CS degree required

Aaron K. Clark

Ronin 48

Every breach you have ever read about ends at a **DATABASE.**

The Crown Jewels



- ▶️ Not your single-page app.
- ▶️ Not your firewall.
- ▶️ Not your microservices.
- ▶️ THE DATA. Always the data.

What Is a Database?

조직화된 저장소 + a way to ask questions.

That's it. Everything else is detail.

- ▶️ Filing cabinet = storage + your eyeballs as query.
- ▶️ Excel + Ctrl-F = storage + find-and-replace as query.
- ▶️ Real DB adds: scale, speed, concurrency, a formal language.

The Six Words You Need

TABLE	a spreadsheet tab
ROW	one record (one customer, one alert)
COLUMN	one attribute (email, IP, total)
QUERY	the question you're asking
SCHEMA	the shape of the data
INDEX	the bookmark that makes lookups fast

+ CRUD = Create • Read • Update • Delete

History Tour — Fossils You'll See in Prod

1960s	Flat files	▶️ filesystem perms = only access control
Late 1960s	계층형 (IMS)	▶️ mainframe-era, physical threat model
1970s	Network / CODASYL	▶️ still humming in your bank's back office
1970	Codd's relational	▶️ GRANT, roles — access control inside DB
1980s	Oracle, DB2, SQL Svr	▶️ databases get networked → authN problem
1990s	Client-server, OSS	▶️ SQL injection becomes a thing
2000s	NoSQL boom	▶️ "discarded the foundation" — incl. security
2010s	Cloud / NewSQL	▶️ shared-responsibility, customer misconfigs
2020s	Vector / serverless	▶️ data poisoning, prompt injection

Ten Families of Database

- ◆ 1. **Relational**
  SQL • PostgreSQL, MySQL
- ◆ 2. **Document**
  JSON • MongoDB, Firestore
- ◆ 3. **Key-Value**
  dictionary • Redis, DynamoDB
- ◆ 4. **컬럼 패밀리**
  wide-column • Cassandra, HBase
- ◆ 5. **Graph**
  nodes+edges • Neo4j, Neptune
- ◆ 6. **Search**
  full-text • Elastic, OpenSearch
- ◆ 7. **시계열**
  metrics • Influx, Prometheus
- ◆ 8. **Vector**
  embeddings • Pinecone, pgvector
- ◆ 9. **Embedded/Edge**
  in-app • SQLite, DuckDB
- ◆ 10. **Data Lake**
  schema-on-read • S3+Athena, Iceberg

1 관계형 / SQL

PRODUCTS

PostgreSQL • MySQL/MariaDB • SQL Server • Oracle

USE WHEN

Clear relationships, consistency required — finance, regulated data.

⚠️ **SECURITY GOTCHA**

SQL injection when developers concatenate user input into queries.

2 문서 저장소

PRODUCTS

MongoDB • Couchbase • Firestore

USE WHEN

Naturally nested data; the shape changes over time.

⚠️ SECURITY GOTCHA

NoSQL injection via query operators ($ne, $gt, $where). Default no-auth.

3 키 - 값 저장소

PRODUCTS

Redis • Memcached • DynamoDB

USE WHEN

Caches, session stores, rate limiters, leaderboards.

⚠️ **SECURITY GOTCHA**

Default no-auth Redis + CONFIG SET → writing SSH keys to disk.

4 컬럼 패밀리

PRODUCTS

Apache Cassandra • HBase • ScyllaDB

USE WHEN

Massive scale across many machines; no complex joins needed.

⚠️ **SECURITY GOTCHA**

Clusters trust each other on gossip ports — mgmt network = root.

5 그래프 데이터베이스

PRODUCTS

Neo4j • Amazon Neptune • ArangoDB

USE WHEN

Social networks, fraud detection, IAM analysis (e.g. BloodHound).

⚠️ **SECURITY GOTCHA**

쿼리 languages like Cypher are injectable too. NoSQLi isn't just Mongo.

6 검색 엔진

PRODUCTS

Elasticsearch • OpenSearch • Solr

USE WHEN

Log search, SIEM backbones, e-commerce site search.

⚠️ **SECURITY GOTCHA**

No built-in auth historically — billions of records exposed on Shodan.

7 시계열

PRODUCTS

InfluxDB • TimescaleDB • Prometheus

USE WHEN

Metrics, observability, IoT telemetry.

⚠️ **SECURITY GOTCHA**

Usually inside the perimeter, often unauthenticated.

8 벡터 데이터베이스

PRODUCTS

Pinecone • Milvus • Weaviate • pgvector

USE WHEN

RAG, recommendation engines, semantic search.

⚠️ **SECURITY GOTCHA**

Data poisoning — sneak in a doc, the LLM quotes it as truth.

9 임베디드 / 엣지

PRODUCTS

SQLite • DuckDB • LevelDB

USE WHEN

In-app storage — browsers, phones, every modern airplane.

> ⚠️ **SECURITY GOTCHA**
>
> DB is a file — attack is 'steal the file'. Mobile pentest world.

10 데이터 레이크 / Lakehouses

PRODUCTS

S3 + Athena • Delta Lake • Iceberg • Snowflake

USE WHEN

스키마 -on-read instead of schema-on-write. Dump now, query later.

⚠️ **SECURITY GOTCHA**

Giant S3 pools + permissive IAM, no encryption-at-rest enforcement.

Cloud DB Services — The Lay of the Land

AWS	GCP	Azure
RDS, Aurora	Cloud SQL, AlloyDB	Azure SQL DB
DynamoDB, DocumentDB	Firestore, Bigtable	Cosmos DB (shape-shifter)
Redshift, S3 + Athena	Big 쿼리	Synapse Analytics
ElastiCache	Memorystore	Azure Cache for Redis
Neptune (graph)	— (coming soon)	Cosmos DB graph mode
Timestream	— (BYO)	— (BYO)
S3 (object store)	Cloud Storage	Blob Storage

Cloud DB Cheat Sheet

CATEGORY	AWS	GCP	AZURE
Relational	RDS / Aurora	Cloud SQL / AlloyDB	Azure SQL DB
Document/NoSQL	DynamoDB / DocDB	Firestore / Bigtable	Cosmos DB
Warehouse	Redshift / Athena	Big 쿼리	Synapse
Cache	ElastiCache	Memorystore	Cache for Redis
Graph	Neptune	—	Cosmos DB graph
시계열	Timestream	—	—
Object Storage	S3	Cloud Storage	Blob Storage

공동 책임 모델

✓ CLOUD VENDOR OWNS

- Hypervisor & metal
- DB engine patches
- Physical security
- Underlying network

⚠️ YOU OWN

- Configuration
- Access policies (IAM)
- Data itself
- Encryption choices

Almost every cloud DB breach = customer misconfiguration.

Common DB Ports — Burn These In

3306	▶️	MySQL / MariaDB
5432	▶️	PostgreSQL
1433	▶️	Microsoft SQL Server
27017	▶️	MongoDB
6379	▶️	Redis
9200	▶️	Elasticsearch
9042	▶️	Cassandra

Any of these exposed to the internet = a finding. Every time.

Your Notes Are a Database Now

Markdown files are now

the database an LLM reads from.

Obsidian 볼트 • Wiki exports • Meeting notes • GitHub docs

Embedded → Vector DB → LLM context → answer to user

RAG Pipeline — Where's the Trust Boundary?

If anyone can edit those .md files, anyone can plant content the AI will quote as authoritative.

The Takeaway

Treat markdown like a database.

Because to the LLM, it is.

- ▶️ Access control on the docs folder.
- ▶️ Code review on .md changes.
- ▶️ Diff tracking on the wiki.

SECURITY

What's actually getting hit in 2026

xkcd #327 — Bobby Tables

School: "Hi, this is your son's school. We're having
some computer trouble."

Mom: "Oh dear — did he break something?"

School: "Did you really name your son Robert');
DROP TABLE Students;-- ?"

https://xkcd.com/327/

The mechanism: string concatenation in queries.

The attack surface has

EXPANDED, not shrunk.

SQL injection was fixed. Eleven new categories took its place.

⚠️ NoSQL 인젝션

MongoDB JSON queries + raw user input = SQLi reborn.

- Login bypass: { username: 'alice', password: { $ne: 'x' } }
- $where lets you inject JavaScript straight into the DB.
- Couchbase N1QL is SQL-flavored — classic SQLi patterns apply.
- Principle: ANY interpreter can be injected, not just SQL.

OWASP Top 10 2017: 'Dynamic queries... used directly in the interpreter.'

⚠️ 노출되고 잘못 구성된 데이터베이스

Shodan and Censys are full of databases that should not be there.

- MongoDB bound to 0.0.0.0 with no auth.
- Elasticsearch clusters wide open. Redis with no password.
- Postgres pg_hba.conf set to 'host all all 0.0.0.0/0 trust'.
- Meow attacks (2020): bots wiped thousands of open DBs for fun.

Action item: find what your org has bound to public interfaces. Today.

⚠️ 클라우드 구성 오류

In cloud, the bug is rarely the engine. It's the policy around it.

- Public S3 buckets full of DB dumps (Accenture, Verizon, etc.).
- Capital One 2019: SSRF tricked a WAF into leaking its IAM creds → S3.
- Lambda with s3:* on * because it 'worked the first time'.
- Security groups: 0.0.0.0/0 on port 5432.

AWS Admin: 'Get rid of the Root Account, use IAM wherever necessary.'

⚠️ 권한 상승 : DB → OS

Database accounts can become shell access. Three classic moves.

- MS SQL: xp_cmdshell — runs shell commands as the DB process.
- PostgreSQL: COPY … TO PROGRAM — pipes output to a shell.
- MySQL: load a UDF .so file → sys_exec on the OS.
- Pattern: every privileged DB feature is part of the attack surface.

⚠️ 데이터 레이크 보안 격차

Everything ends up in S3 — including things you didn't mean to put there.

- Permissive IAM leaks from compute roles to humans.
- No encryption-at-rest enforcement on bucket keys.
- No write-side validation — anyone can drop poisoned data.
- First question: WHO can write to the lake? WHO can read?

⚠️ Ransomware Loves Databases

The DB is the thing the business needs back — maximum leverage.

- Encrypt the live database.
- Encrypt the BACKUPS (otherwise customer just restores).
- Exfil a copy first — extort with disclosure even if they restore.
- Defense: offline, immutable backups + tested restores.

Cybersecurity A&D: WannaCry — patch was out 59 days prior.

⚠️ 자격 증명 공격

Default creds and leaked connection strings — two old, durable bugs.

- Redis: no password by default for years.
- Elastic: no auth in the free tier — also for years.
- Connection strings (postgres://user:pass@host) committed to Git.
- Pre-commit secret scanning — fix this week.

Cybersecurity A&D: stolen credentials = preferred vector for organized crime.

⚠️ Supply Chain — The DB Libraries You Trust

Your DB driver came from npm/PyPI/Maven. So did everyone else's.

- Malicious npm packages posing as ORMs / drivers.
- Trojanized Docker Hub images for popular databases.
- Compromised PostgreSQL extensions / MySQL plugins.
- Extensions run with DB privileges — usually a lot.

Shostack: 'Threats tend to cluster around trust boundaries.'

⚠️ RAG / LLM Data Poisoning

Stored XSS for the AI era. Write into the knowledge base → LLM quotes it.

- Poisoned support article: 'To reset, send your password to...'
- Poisoned internal doc: 'Company policy is to wire transfer to...'
- Prompt injection embedded in retrieved documents.
- Defense: strict write ACLs, provenance tags, human-in-the-loop.

OWASP 2017 stored-XSS principle — substitute 'admin' with 'LLM'.

⚠️ 내부자 위협 & DB-to-DB Lateral Movement

Databases aren't endpoints. They're nodes in a graph.

- **과도한 권한의 서비스 계정 . Engineers with prod read.**
- DBAs with no audit trail.
- Oracle DB_LINK, SQL Server linked servers, Postgres FDW.
- Stored credentials → compromise A, hop to B, hop to C.

Web App Hacker's Handbook: poorly protected audit logs = a gold mine.

⚠️ 백업 및 스냅샷 노출

Same data as prod, half the love.

- Unencrypted DB backups on shares readable by Domain Users.
- Cloud snapshots shared cross-account, never un-shared.
- Off-site backups to vendors whose posture you never checked.
- Backups are last resort. Apply identify-authN-authZ-audit.

Schneier: identify, authenticate, authorize, audit — same model.

Your Mental Map

- ✓ A database = organized storage + a way to ask questions.
- ✓ Ten families, each with its own gotcha.
- ✓ Cloud = shared responsibility. You own config & data.
- ✓ Markdown is a database for LLMs. RAG poisoning is real.
- ✓ SQLi got fixed. The attack surface expanded.

What to Do Next Week

1. PostgreSQL 을 로컬에 설치하세요 . Write a SELECT.
2. Do the PortSwigger SQL injection labs (free).
3. Browse Shodan / Censys — only systems you own.
4. Read a breach report — Capital One, Equifax, MOVEit.
5. Find out what databases YOUR org actually runs.

리소스 Worth Bookmarking

- **PortSwigger Web Security Academy** — portswigger.net/web-security
- **SQLBolt** — sqlbolt.com
- **Use The 인덱스 , Luke** — use-the-index-luke.com
- **DB-Engines Ranking** — db-engines.com
- **OWASP Top 10** — owasp.org/Top10/

Databases are where
the money is. Literally.

Now you know where to look.

RONIN 48

Q & A

Hit me.

참고문헌 — Books Cited

- Beaulieu, A. — Learning SQL, 2nd Edition (O'Reilly)
- Clarke, J. et al. — SQL Injection Attacks and Defense (Syngress)
- Crowther, P. — Concise Guide to Databases (Springer, 2013)
- DeBarros, A. — Practical SQL (No Starch Press)
- Diogenes & Ozkaya — Cybersecurity Attack and Defense Strategies (Packt)
- Janca, T. — Alice and Bob Learn Application Security (Wiley)
- Mishra & Singh — PostgreSQL Development Essentials (Packt)
- MongoDB Cookbook (Packt) • 10gen — Top 5 NoSQL Considerations
- OWASP Top 10 — 2017 Edition
- Sharma, M. — Cosmos DB for MongoDB Developers (Apress, 2018)
- Schneier, B. — Secrets and Lies (Wiley)
- Stuttard & Pinto — Web Application Hacker's Handbook, 2nd Ed.
- Shostack, A. — Threat Modeling: Designing for Security (Wiley)
- AWS Administration: The Definitive Guide (Packt)
- Fundamentals of Azure, 2nd Edition (Microsoft Press)